

SOC/L1 - 3.1. Introduction to EDR

Introduction to EDR

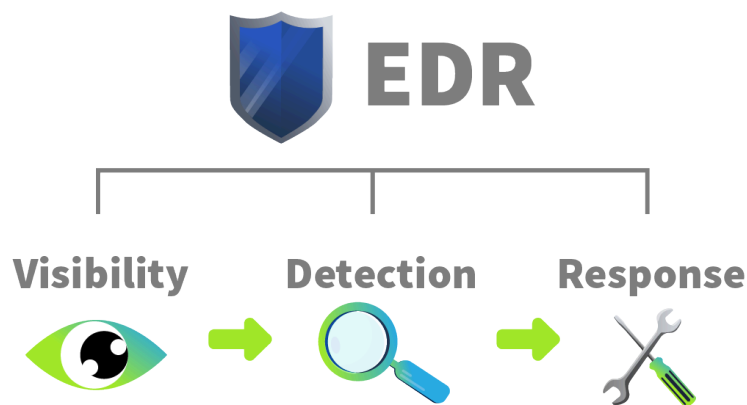
1 - Introduction

Endpoint Detection and Response (EDR) is a security solution designed to monitor, detect, and respond to advanced threats at the endpoint level. As a SOC analyst, it is essential for you to understand how the EDR works since it is a widely adopted solution in organizations to protect their endpoints.

2 - What is an EDR?

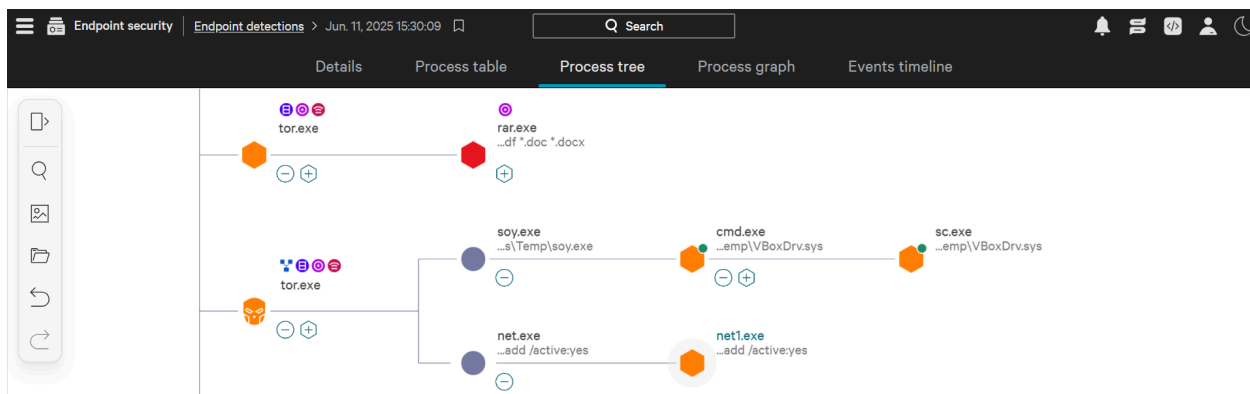
To ensure endpoint devices are protected even out of the network, we need a security solution that guards all devices in different areas and is capable of fighting advanced threats. Endpoint Detection and Response (EDR) is a security solution that offers deep-level protection for endpoints. No matter where the endpoints are, the EDR will make sure they are monitored constantly and threats are detected.

Features of EDR: There are three main features of an EDR, which can also be referred to as the three pillars of an EDR solution.



Visibility: A good analysis often depends on the available level of visibility of the activity. This is one of the features of **EDR** that makes it unique from other endpoint security solutions. The level of visibility EDR provides is impressive. It collects detailed data from the endpoints, which includes process modifications, registry modifications, file and folder modifications, user actions, and much more. It then presents this information in a very structured format to the analyst. The analyst can see the whole process tree with a complete activity timeline of the sequence of actions. The analyst can also access the historical data of any endpoint for threat hunting or any other purpose.

The following screenshot shows graphical representation of a process tree. We can see which processes were spawned on the endpoint. Each node represents a process. The lines connecting them represents their relationship. If we click on the  icon given with each process, we will be able to see all the network connections, registry changes, file changes etc. associated with that process.



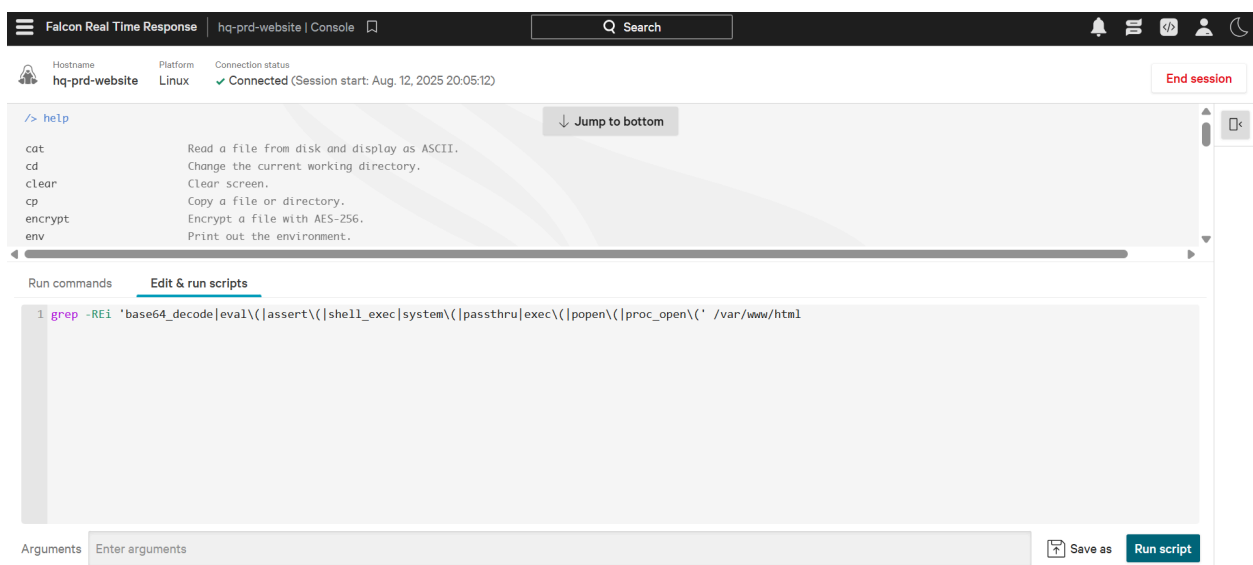
Along with the process trees, there are many other features available in the EDRs which maximize the visibility.

Detection: The detection feature of EDR wins over traditional detection capabilities. It incorporates signature-based detections as well as behavior-based detections, such as unexpected user activities. With modern machine learning capabilities, it identifies any deviation from the baseline behavior and instantly flags it. It can also detect fileless malware that resides in memory. It also allows us to feed custom IOCs for threat detections.

The following screenshot shows a dashboard of all the detections happening on the different endpoints. Each detection is represented by a row with different fields including the severity of the detection, time, triggering file, hostname, username, and more. The Tactic via Technique field maps the detection with MITRE. Any detection when clicked will show us rich details which helps a SOC analyst during the analysis.

Severity	Detect time	Name	Tactic via technique	Command line
High	09:00:44	Process on host powershell.exe on SRV-01 by Administrator	Defense Evasion via	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -WIN...
High	15:34:51	Process on host Setup.exe on LPT-12766 by j.adams	Machine Learning ...	"C:\Users\j.adams\Downloads\Photoshop 26.3 (Cracked)\Setup.exe"
Low	14:01:45	Process on host cmd.exe on LPT-10075 by k.smith	Malware via Adware	"C:\WINDOWS\system32\cmd.exe" /d /c TIMEOUT 5 & cmd /d /c del "C...
Low	14:01:45	Process on host appbundle.exe on LPT-10075 by k.smith	Malware via Adware	Triggering file appbundle.exe

Response: EDR also empowers analysts to take action on detected threats. These actions can be taken at any endpoint within the central EDR console. Imagine getting a detection on the EDR with full-fledged details on when, where, and what happened, and you have to opt for the best possible action for that detection. As an analyst, you may decide to isolate a complete endpoint, terminate a process, or quarantine some files. You can also connect to the host remotely and execute actions independently. You can do this all from within the EDR console. The following screenshot shows the actions available that can be taken on the host after connecting to it.



Which feature of EDR provides a complete context for all the detections?
Visibility

Which process spawned sc.exe? cmd.exe

3 - Beyond the Antivirus

Why do we need an EDR when we already have an Antivirus (AV) on the endpoints?

Both of these security solutions have the same motive of protecting the endpoint on which they are installed. However, both differ in the level of protection they provide. Let's assume an airport is an endpoint that needs protection. One layer of protection is to check the passports of people when they pass through

immigration. The immigration check (AV) monitors incoming people and matches their passports with a list of known criminals in its database. If there is a match, the entry is blocked and caught.

Attack Steps	AV's Response	EDR's Response
Step #1	Does nothing if the downloaded file has no previous signature in the database	Logs the file download activity and monitors it
Step #2	Does nothing upon the opening of the document since winword.exe is a legitimate utility	Records the execution of winword.exe and keeps monitoring
Step #3	Does nothing if the executed macro has no previous signature	Detects and flags the macro execution due to the unusual parent-child relationship of winword.exe and PowerShell.exe processes
Step #4	Typically, AVs will not detect obfuscated PowerShell scripts	Flags the obfuscated script execution
Step #5	Will not flag malicious injection into svchost.exe since it does not monitor the memory injections	Detects Process Injection in svchost.exe
Step #6	Lacks Network Level Visibility	Flags the unexpected behaviour of svchost.exe, making an outbound connection
Final Action	May be marked as clean	Generates an alert with the full attack chain and enables the analyst to take actions from within the EDR

In the given analogy, what presents an AV? immigration check

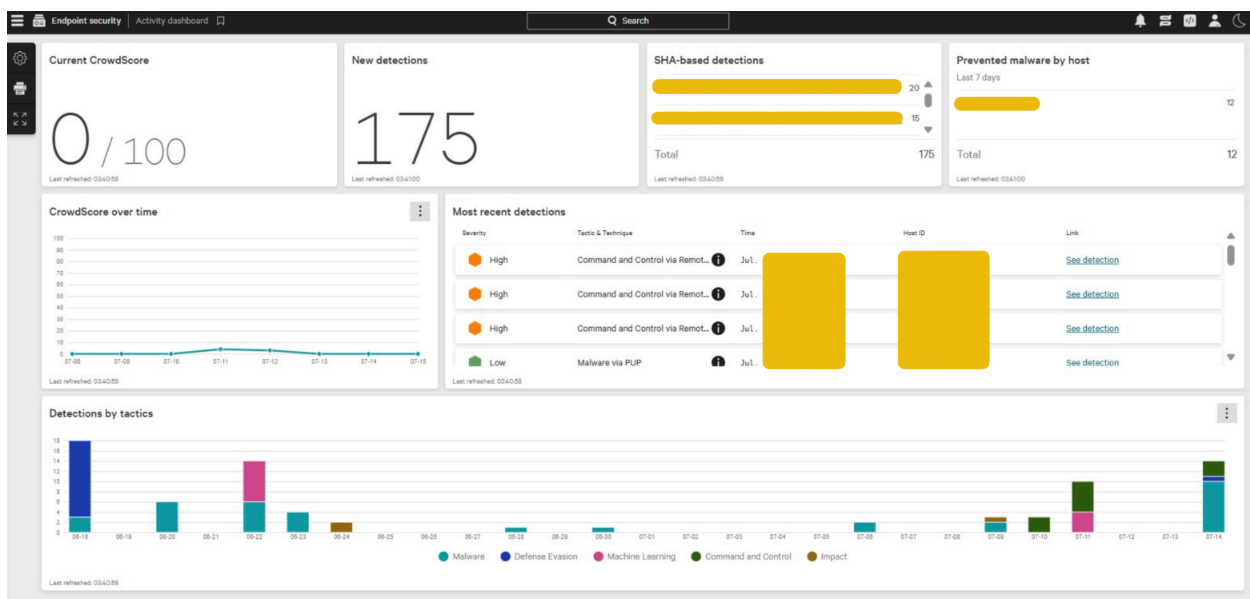
Which legitimate process was hijacked by the attacker in the scenario?
svchost.exe

Which security solution might mark this activity as clean? Antivirus

4 - How an EDR works?

Agents: We can integrate multiple endpoints with our EDR and manage them through a centralized console. There are EDR agents that we have to deploy inside those endpoints. These agents are also sometimes referred to as sensors. They are the eyes and ears of the EDR. Their job is to sit at the endpoint and monitor all the activities. The information about these activities is sent in detail to the EDR central console in real time. The EDR agents can do some basic signature-based and behavior-based detections by themselves and send them to the EDR console, which triggers alerts.

EDR Console: All the detailed data sent by the EDR agents is correlated and analyzed through complex logic and machine learning algorithms. The threat intelligence information is matched with the collected data. The EDR is just like the brain connecting all the dots. These dots connect to form a detection, often called an alert. The following screenshot shows the dashboard of an EDR console. All the data from the endpoint agents is coming into this console, and the detections are happening here. This dashboard gives a holistic view of the current status of detections in all the endpoints.



What happens after Detection?

When a detection comes, it's a SOC analyst's responsibility to acknowledge the alert and prioritize it. The prioritization is made easy by the EDR itself. It gives severities to all the alerts (Critical, High, Medium, Low, Informational). The alert

with the highest severity is investigated as a priority. For the investigation, once the alert is clicked, the analyst can see all the details of the detection. This includes any files executed, processes executed, network connection attempts, registry modifications, and much more. Based on the available data, the analyst's job is first to use their expertise to determine if the alert is a false positive or a true positive. In case of a true positive, the analyst can take actions from within the EDR console.

EDR with Other Tools

As a SOC Analyst, it is essential to understand that although a standalone EDR provides enough information to detect and respond to threats in an endpoint, it works alongside other security solutions to form a larger security ecosystem. Within a network, you will see Firewalls, DLPs, Email Security Gateways, IAMs, EDRs, and other security solutions protecting the different components of the network. To minimize the effort and maximize the efficiency, all these security solutions are integrated with a SIEM solution that becomes the central point of investigation for the analysts. We will also discuss the SIEM solution in detail in the upcoming rooms of this module.

Which component of the EDR is responsible for collecting telemetry from the endpoints? Agent

An EDR agent is also known as a? sensor

5 - EDR Telemetry

Telemetry is the black box of an endpoint with everything necessary for detection and investigation.

Collected Telemetry: Usually, many activities are going on in the endpoints, most of which are legitimate. It is often difficult to differentiate between regular and malicious activity. The more data is collected, the better judgments can be made. EDR collects detailed telemetry from the endpoints. Let's take a brief look at some of the telemetry that it collects:

- **Process Executions and Terminations:** It keeps track of all the running and idle processes, which helps to identify suspicious child-parent process

relationships, suspicious executables initiating a process, malware payload, etc.

- **Network Connections:** All the endpoints' network connections are monitored, which helps identify any connection to a C2 server, unusual port usage, data exfiltration, or lateral movement within the network.
- **Command Line Activity:** It captures all the commands executed on the endpoints in CMD, PowerShell, etc., which helps to identify malicious command execution, obfuscated PowerShell script executions, which are often missed by a traditional antivirus.
- **Files and Folders Modifications:** Threat actors modify different files and folders during data staging, ransomware executions, and malicious file dropping. The EDR tracks this.
- **Registry Modifications:** The registry is a goldmine of information about the configurations in a Windows system. There are many registry modifications that occur during a malicious activity, and most of these are monitored by the EDR.

EDR collects much more than this data from an endpoint. It uses complex logic and machine learning algorithms to assess the activities. Advanced threats keep most of their activities stealthy, using legitimate utilities during execution. Individually, their activities may seem harmless, but when observed through detailed telemetry, they tell a different story. This detailed telemetry not only helps the EDR detect advanced threats and make better judgments on the legitimacy of the activities, but it is also very helpful for the analysts during the investigations. The analysts can understand the full chain of events, identify the root cause, and reconstruct the attack timeline.

Which telemetry data helps in detecting C2 communications? Network Connections

Where are the configuration settings of a Windows system primarily stored? registry

6 - Detection And Response Capabilities

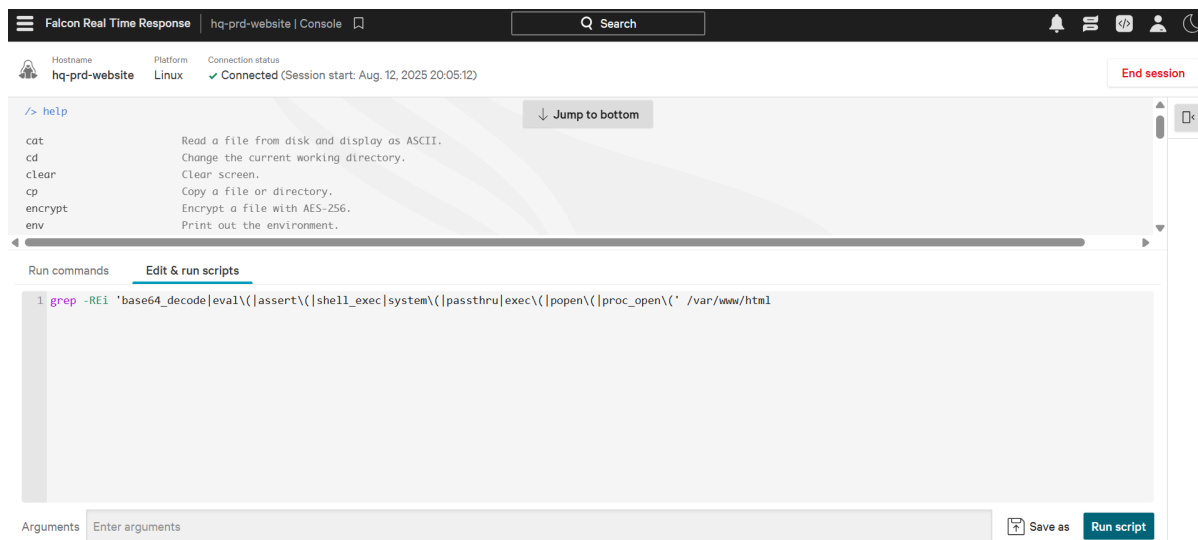
Detection: Based on the telemetry received from the endpoints, some advanced detection techniques are applied to this data. Some of these techniques include:

- **Behavioral Detection:** Instead of just matching the signatures with known threats, it observes the complete behavior of a file. Advanced threats craft their malware to look clean and use legitimate processes to carry out their attack. EDR catches this behavior. **Example:** A process winword.exe spawning PowerShell.exe will be flagged by the EDR due to the behavior. A Word document spawning a PowerShell is an unusual parent-child relationship.
- **Anomaly Detection:** With time, EDR understands the baseline behavior of the endpoints. Any activity that deviates from this behavior will be flagged. During any malicious activity, the endpoint's behavior deviates from normal. EDR picks it up. Sometimes, this can generate false positives as well. However, with the full context it gives, the analyst can identify its legitimacy. **Example:** On one of the endpoints, a process modifies an auto-start registry key, which is not a common behavior on the endpoint.
- **IOC matching:** EDRs have some strong threat intelligence field integrations. Except for zero-day attacks, most of the attacks have indicators published in the threat intelligence feeds. EDR flags any activity that matches any known IOC. **Example:** A user downloads a file that drops an executable. The executable is often used in a specific attack. The hash of this executable will get matched with the threat intelligence feed and instantly flagged by the EDR.
- **MITRE ATT&CK Mapping:** Any activity flagged by the EDR is not only marked as malicious or suspicious but also mapped with the MITRE Tactic and Technique (attack stage) that the particular activity was on. This proves to be very helpful for the analysts. **Example:** If the EDR flags the creation of a scheduled task for any reason, it will likely map this activity to the following:
 - Tactic: Persistence
 - Technique: Scheduled Task/Job
- **Machine Learning Algorithms:** Advanced threat actors try to evade defenses as much as possible, and their activities may sometimes bypass advanced detection techniques. Modern EDRs have machine learning models trained by a large dataset of normal and malicious behaviors. This can detect complex

patterns of an attack.**Example:** Attacks in which the individual actions are not inherently malicious, but the ML algorithm identifies the whole chain of activities as malicious. Fileless attacks and multi-staged intrusions are often detected through this.

Response: The next step after any detection is the response. EDR offers both automated and manual responses. You can make policies to block known malicious behaviors automatically. However, manual response gives you a wide range of response capabilities. Let's discuss some of them.

- **Isolate Host:** During any malicious activity on an endpoint, you can isolate that endpoint from the network through EDR. This is a very effective function for containing malicious activity. Most attacks start from a single endpoint and move laterally to other endpoints to compromise the whole network. Isolating the infected endpoint on time can stop this from happening.
- **Terminate Process:** Not every malicious activity requires host isolation. Some hosts run the core business operations, and isolating them can cause more loss than the malicious activity. In such cases, terminating a process is enough to neutralize the malicious activity. The analysts get this option in the EDR. They can terminate any process at any time. This action should be taken consciously since terminating a legitimate process can disrupt the endpoint
- **Quarantine:** If a malicious file comes into the endpoint, it can be quarantined. Quarantine ensures that the file is moved to an isolated location where it can not be executed. The analysts can then review the file to restore or permanently remove it.
- **Remote Access:** Analysts can also remotely access the shell of any endpoint. This is often done when the EDR's built-in response is not enough to take action on a specific activity. Through remote access, analysts can gain deeper visibility into the system or take custom actions within the endpoints. The analysts can also run scripts or collect their desired data from the host through remote access. Below is an example of CrowdStrike Falcon EDR's RTR (Real Time Response) console, which allows analysts to remotely access the shell of any endpoint and run commands and scripts.



- **Artefacts Collection** Sometimes, the analysts may need to extract some data from the endpoints for detailed forensic investigation or reporting for legal actions. Analysts can extract important artefacts from the endpoints without physically accessing the device. The most commonly extracted artefacts include:

- Memory Dump
- Event Logs
- Specific Folder Contents
- Registry Hives

The Detection and Response capabilities of EDR solutions differ from those of traditional endpoint protection solutions. Modern EDRs are introducing more advanced detection techniques.

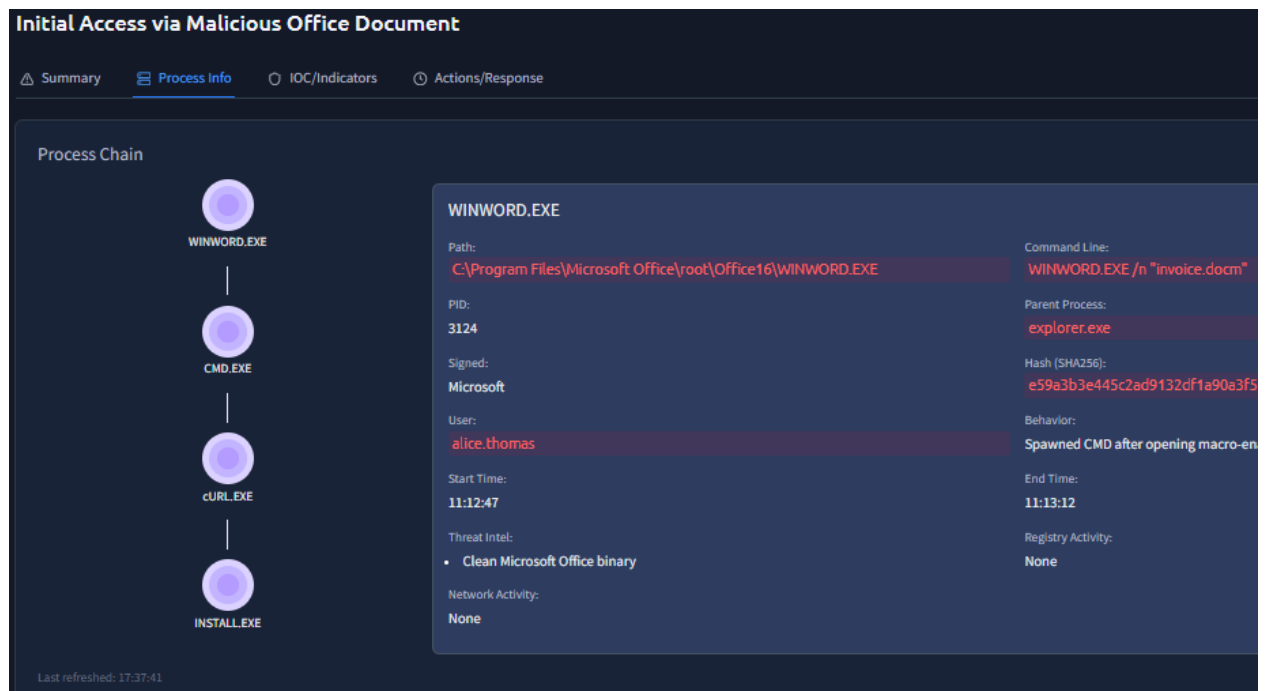
Which feature of the EDR helps you identify threats based on known malicious behaviours?

IOC Matching

7 - Investigate an alert on EDR

Which tool was launched by CMD.exe to download the payload on DESKTOP-HR01?

CURL.exe



What is the absolute path to the downloaded malware on the DESKTOP-HR01 machine?

C:\Users\Public\install.exe

Initial Access via Malicious Office Document

Summary Process Info **IOC/Indicators** Actions/Response

Associated Indicators of Compromise (IoCs)

Type	Value
File Path	C:\Users\Public\install.exe
File Name	install.exe
Domain	ayebd.thm
IP Address	1.161.138.92
SHA256	9e107d9d372bb6826bd81d3542a419d6eaf1e3f5b94fc3b1f69413c5c30ef2e5
File Path	C:\User\alice\Downloads\invoice.docm

Last refreshed: 17:38:31

What is the absolute path to the suspicious syncsvc.exe on the WIN-ENG-LAPTOP03 machine?

C:\Users\haris.khan\AppData\Local\Temp\syncsvc.exe

Credential Dumping via LSASS Memory Access

Summary **Process Info** IOC/Indicators Actions/Response

Process Chain

```

graph TD
    explorer.exe --> syncsvc.exe
    syncsvc.exe --> lsass.exe
  
```

explorer.exe

Path:	C:\Windows\explorer.exe	User:	haris.khan
Signed:	Microsoft	Hash (SHA256):	7a1c5f2c2d451e9e27b2d3eeca5a1989b7796f5c4a647889bf36c1f71d6fe8e0
Behavior:	Launched syncsvc.exe	Start Time:	14:12:50
End Time:	14:14:00	Threat Intel:	Clean, system-signed process
Registry Activity:	None	Network Activity:	None

Last refreshed: 17:39:41

On which URL was the exfiltration attempt being made on WIN-ENG-LAPTOP03?

https://files-wetransfer.com/upload/session/ab12cd34ef56/dump_2025.dmp

Credential Dumping via LSASS Memory Access

Summary | **Process Info** | IOC/Indicators | Actions/Response

Process Chain

```

graph TD
    explorer.exe --> syncsvc.exe
    syncsvc.exe --> lsass.exe
  
```

syncsvc.exe

Path: `C:\Users\haris.khan\AppData\Local\Temp\syncsvc.exe`

Parent Process: `explorer.exe`

Hash (SHA256): `7a1c5f2c2d451e9e27b2c3eec5a1989b7796f5c45a647889bf36c1f71d6fe6e0`

Behavior:

- Accessed memory of `lsass.exe`
- Wrote dump to disk

End Time: `14:13:10`

Registry Activity:

- `HKLM\SYSTEM\CurrentControlSet\Services\syncsvc`
- `HKCU\Software\Microsoft\Windows\CurrentVersion\Run\syncsvc`

Command Line: `syncsvc.exe -ma lsass.exe C:\Users\Public\dump_2025.dmp`

Signed: **No**

User: `haris.khan`

Start Time: `14:12:57`

Threat Intel:

- Matches known credential dumping tool
- ATT&CK ID: T1003.001

Network Activity:

- Attempted exfil to: `https://files-wetransfer.com/upload/session/ab12cd34ef56/dump_2025.dmp`
- Domain: `files-wetransfer.com`
- IP: `100.42.28.64`
- Port: `80`
- Status: **Blocked by EDR**

Last refreshed: 17:40:32

What was UpdateAgent.exe labelled by Threat Intel on DESKTOP-DEV01?

Execution from AppData Directory

Summary | **Process Info** | IOC/Indicators | Actions/Response

Process Chain

```

graph TD
    explorer.exe --> UpdateAgent.exe
  
```

UpdateAgent.exe

Path: `C:\Users\daniel.richards\AppData\Roaming\UpdateAgent.exe`

PID: `1372`

Signed: **No**

Network Activity:

- IP: `10.10.20.5`
- Port: `8080`
- Protocol: `HTTP`

Hash (SHA256): `9f9f2e4a44d1a3f711e26c8ab60b392cd34e2b36b012f...`

End Time: `13:09:17 UTC`

Command Line: `C:\Users\daniel.richards\AppData\Roaming\UpdateAgent.exe`

Parent Process: `explorer.exe`

Behavior: **Initiated outbound connection to 10.10.20.5**

Threat Intel: **Known internal IT utility tool**

Start Time: `13:09:11 UTC`

Last refreshed: 17:41:50